STRIDE THREAT MODEL

1. Introduction

STRIDE is a threat modelling methodology used to identify and analyze security threats in an application or system. It helps understand possible attacks, their impact and suitable security controls.

In this project, the STRIDE methodology is used to analyze the authorized local training web application (LAB-01) and deliberately vulnerable virtual machine (LAB-02).

2. STRIDE Categories

1. Spoofing

Spoofing occurs when an attacker pretends to be a legitimate user or system.

Example: An unauthorized person attempts to access the web application using another user's identity.

Mitigation: Use strong passwords, multi-factor authentication and secure session management.

2. Tampering

Tampering means modifying data without proper authorization.

Example: An unauthorized user attempts to modify application records.

Mitigation: Apply input validation, access controls and data integrity checks.

3. Repudiation

Repudiation occurs when a user denies performing an action without sufficient records to verify it.

Example: A user denies making a particular change in the application.

Mitigation: Maintain secure audit logs with timestamps and user activity details.

4. Information Disclosure

Information disclosure occurs when confidential information is exposed to unauthorized users.

Example: A user accesses another user's private information.

Mitigation: Use encryption, proper authentication and role-based access control.

5. Denial of Service

Denial of Service occurs when a system becomes unavailable because its resources are exhausted or disrupted.

Example: Excessive requests affect the availability of the training web application.

Mitigation: Implement rate limiting, resource monitoring and request controls. Do not perform denial-of-service testing in this engagement.

6. Elevation of Privilege

Elevation of privilege occurs when a user gains permissions beyond their authorized access level.

Example: A normal user attempts to access administrator-only functions.

Mitigation: Apply role-based access control, least privilege and proper permission validation.

3. STRIDE Threat Register

Threat	Possible Risk	Risk Level	Recommended Mitigation
Spoofing	Unauthorized login	High	Strong authentication
Tampering	Unauthorized data modification	High	Input validation and integrity checks
Repudiation	Untraceable user actions	Medium	Secure audit logging
Information Disclosure	Exposure of confidential data	High	Encryption and access control
Denial of Service	Application unavailability	High	Rate limiting and monitoring
Elevation of Privilege	Unauthorized administrator access	High	Role-based access control

Note: These are preliminary risk ratings for the proposed lab. Actual severity must be validated based on the system configuration and testing evidence.

4. Abuse Cases

1. An unauthorized person attempts to log in as a legitimate user.
2. A user attempts to modify information without permission.
3. A user denies an activity because proper audit logs are unavailable.
4. An unauthorized user attempts to view confidential information.
5. Excessive requests may affect application availability.
6. A normal user attempts to access administrator privileges.

5. Ranked Security Mitigations

Priority 1 – High Priority:

- Implement strong authentication.
- Protect sensitive information.
- Validate user permissions.
- Prevent unauthorized data modification.

Priority 2 – Medium Priority:

- Maintain secure audit logs.
- Monitor application activity.
- Review access permissions regularly.

6. Conclusion

The STRIDE threat model helps identify six major categories of security threats in the authorized lab environment. By identifying possible abuse cases and applying suitable mitigations, the security of the training web application and virtual machine can be improved.